PHOENIX Project — Cybersecurity Threat Analysis

CY005: Map Mitigations

Introduction

Identifying threats is only the first half of threat modelling. The second half is deciding what to do about each one. Mitigation mapping connects every identified threat to a specific, implementable security control which a countermeasure that prevents the threat from being realised, detects it when it occurs, or limits the damage it causes once it has succeeded. Without this mapping, the STRIDE analysis and risk identification work produced across CY005 remain analytical outputs rather than actionable security guidance for the engineering team.

This document maps mitigations for all twenty-seven STRIDE threats identified by in the **CY005 STRIDE analysis**, using the risk ratings established by Himanshu Khanna in the **CY005 Identify Risks** task to prioritise the most critical controls. Of the twenty-seven threats, eighteen are rated Critical and seven are rated High which meaning that the overwhelming majority of Phoenix's threat landscape requires genuine, well-implemented security controls rather than monitoring alone. The two Medium-rated threats receive lighter-touch mitigations proportionate to their risk level.

Section 1 — External Data Feed Mitigations

The external data feeds are the first and most exposed boundary in the PHOENIX system. The risk identification work rates five threats at this boundary as Critical as feed spoofing (ST-01, ST-02), data tampering in transit (ST-06), denial-of-service against feed endpoints (ST-22), and stream processing compromise after the validation gate (ST-08). These Critical ratings reflect the fact that corruption at the ingestion layer propagates through every downstream component simultaneously: a compromised feed produces corrupted AI model outputs, corrupted Correlation Engine risk scores, and ultimately suppressed or falsified community alerts. The mitigations here therefore carry the highest priority in the overall security design.

Mitigation M-01 — TLS 1.3 with Certificate Pinning for All External Feed Connections

Threats addressed: ST-01 (Spoofing, Critical), ST-02 (Spoofing, Critical), ST-06 (Tampering, Critical)

Vulnerability addressed: V1 — No continuous check on feed content after authentication

Control type: Preventive

Component: External Sources of Disasters / External Sources of Cyber Threats & Scams

All connections between PHOENIX and its external data providers must be encrypted using TLS 1.3 with certificate pinning. Standard TLS verifies that a server's certificate was signed by a trusted certificate authority, but certificate pinning goes further then it hardcodes the expected certificate fingerprint into the PHOENIX client, so that even a fraudulent certificate signed by a compromised authority is rejected immediately. This directly mitigates the hazard severity downgrade scenario identified in the attack scenarios document, where a state-sponsored

attacker uses a man-in-the-middle position to modify the BoM feed in transit. Because the risk identification rates both the spoofing and tampering threats at this boundary as Critical by reflecting that a successful attack leaves communities completely unprotected during a real disaster and there is no acceptable version of this control that is less rigorous than certificate pinning with TLS 1.3.

Certificate pinning also protects against the feed spoofing scenarios ST-01 and ST-02, where an attacker uses DNS spoofing or a fraudulent API endpoint to impersonate BoM or Scamwatch. By hardcoding the expected certificate, PHOENIX cannot be redirected to an attacker-controlled server regardless of how the DNS resolution is manipulated so the connection will fail certificate verification and trigger a Failure to Fetch alert rather than silently accepting attacker-controlled data.

Mitigation M-02 — Cryptographic Hash Verification of Incoming Feed Data

Threats addressed: ST-06 (Tampering, Critical), ST-07 (Tampering, High)

Vulnerability addressed: V1 — No continuous check on feed content after authentication; V2 — No detection of unusual patterns in incoming data

Control type: Preventive / Detective

Component: Data Validation Layer

Beyond transport-layer encryption, every data packet received from external sources should carry a cryptographic hash which computed by the provider using a shared HMAC key that PHOENIX verifies before the data is admitted to the pipeline. Any packet whose computed hash does not match its content is rejected and logged as a potential tampering event. This control addresses the gap that the risk identification document identifies under vulnerability V1: certificate pinning secures the transport channel but does not verify that the content arriving from an authenticated source has not been manipulated upstream of that source.

The schema validation gate identified under ST-07 which rated High by the risk identification as it's specifically vulnerable to semantically valid but malicious payloads that pass format checks while carrying harmful content. Combining hash verification with strict whitelist-based schema validation by accepting only messages that precisely match expected field types, value ranges, and structure creates two independent barriers at the ingestion boundary. An attacker must bypass both the transport-layer integrity check and the content-level schema verification to introduce malicious data, significantly raising the effort required for a successful injection attack.

Mitigation M-03 — Rate Limiting and Anomaly Detection on Feed Submission Volumes

Threats addressed: ST-02 (Spoofing, Critical), ST-12 (Tampering, Critical)

Vulnerability addressed: V2 — No detection of unusual patterns in incoming data; V21 — Quality filter on feedback is not foolproof

Control type: Detective / Preventive

Component: External Sources of Cyber Threats & Scams / Data Ingestion Layer

The risk identification document rates the model retraining loop as Critical with a High likelihood by specifically noting that coordinated adversarial feedback submissions require no technical sophistication beyond organisation and persistence. The coordinated bot submission attack scenario is the clearest example of this: an attacker does not need access to PHOENIX at all to degrade its detection accuracy. They simply flood the Scamwatch platform that PHOENIX ingests with fabricated reports. The mitigation is anomaly detection on feed submission

volumes: PHOENIX maintains a baseline of normal daily submission rates for each ingested source and triggers an alert whenever volume exceeds a statistically significant deviation from that baseline.

When an anomalous volume spike is detected, incoming data from the affected feed enters a quarantine buffer rather than being admitted directly to the pipeline. The AI model's weighting of that feed's inputs is temporarily reduced, attenuating the influence of potentially poisoned data on risk scoring outputs until the anomaly is assessed by the operations team. This response ensures that a coordinated bot campaign can degrade PHOENIX's performance only marginally rather than catastrophically, buying time for human review without halting the system's overall operation.

Mitigation M-04 — Redundant Feed Sources, Cached Fallback, and Circuit Breaker Pattern

Threats addressed: ST-22 (Denial of Service, Critical), ST-23 (Denial of Service, Medium)

Vulnerability addressed: V3 — Single point of failure on external API connections

Control type: Preventive / Corrective

Component: Data Ingestion Layer / Failure to Fetch / Retry Mechanism

The risk identification flags ST-22 as Critical with High likelihood as denial-of-service attacks against external data endpoints are among the simplest and most commonly executed attacks in cybersecurity, and vulnerability V3 identifies a single point of failure on external API connections as a structural weakness in the current PHOENIX design. The mitigation addresses this at an architectural level: PHOENIX should not depend on a single live connection for disaster context. Multiple BoM endpoints should be configured with automatic failover, and a rolling cache of recent feed data should be maintained with a defined maximum staleness threshold.

The retry mechanism itself requires specific attention because vulnerability V3 creates a second-order risk: the retry loop intended to maintain resilience can be weaponised as a resource exhaustion vector. The circuit breaker pattern directly addresses this rather than retrying indefinitely, the retry logic applies exponential backoff with a hard maximum retry count. After the maximum is reached, the circuit opens, PHOENIX operates in degraded mode with cached data, and the retry loop does not resume until an operator explicitly resets the circuit. ST-23 is rated Medium by the risk identification reflecting that this is a niche attack, but the circuit breaker pattern resolves it at negligible implementation cost as a byproduct of the broader resilience architecture.

Section 2 — Stream Processing and Pipeline Mitigations

The stream processing layer carries four Critical-rated threats according to the risk identification: Kafka topic poisoning (ST-08), Kafka denial of service (ST-21), Kafka broker privilege escalation (ST-27), and the alert delivery API denial of service (ST-20 targets the output end of the same pipeline architecture). The risk identification specifically identifies vulnerability V16 — the Kafka broker could be accessed by unauthorised users — as the shared weakness across three of these four Critical threats, making it the highest-priority vulnerability to address in this section. The common thread across all pipeline threats is that they occur downstream of the Data Validation component, meaning that data introduced at this layer appears to all downstream consumers as having passed validation.

Mitigation M-05 — Kafka Broker Authentication and Per-Topic Access Control Lists

Threats addressed: ST-08 (Tampering, Critical), ST-21 (Denial of Service, Critical), ST-27 (Elevation of Privilege, Critical)

Vulnerability addressed: V16 — Kafka broker could be accessed by unauthorised users

Control type: Preventive

Component: Stream Processing — Kafka

Vulnerability V16 is identified as the shared weakness across three Critical-rated threats, making Kafka broker access control the single highest-priority mitigation in this section. The control has two components. First, strong mutual TLS authentication must be required for all connections to the Kafka broker, and no unauthenticated connections should be accepted, and default credentials must be replaced with cryptographically strong service account credentials stored in a secrets management vault. Second, per-topic Access Control Lists must restrict every service account to only the permissions it requires consumer-only accounts have no produce permissions; producer accounts are restricted to their specific topics; no account has broker-wide administrative access except a dedicated, rarely used admin account whose usage generates an alert on every invocation.

Complementing access controls, all messages entering Kafka topics should be signed with a producer-specific HMAC. Downstream consumers verify the signature before processing by a message from an unexpected producer or with an invalid signature is rejected and logged as a potential injection event. This message signing layer means that even a compromised service account cannot silently inject messages: the injection attempt generates a detectable signature verification failure. All Kafka broker operations should be logged in an immutable audit trail that records every produce and consume operation with the authenticated service account identity and timestamp.

Mitigation M-06 — Firebase Security Rule Enforcement and Server-Mediated Write Access

Threats addressed: ST-19 (Information Disclosure, High), ST-08 (Tampering, Critical) — Firebase pathway

Vulnerability addressed: V20 — Anyone can submit feedback with no deep content check

Control type: Preventive

Component: Stream Processing — Firebase Community Interface

The risk identification notes that Firebase misconfiguration is one of the most commonly reported security issues in real-world systems, and vulnerability V20 identifies the absence of deep content checking on the community feedback pathway as a structural gap. Firebase security rules must follow a default-deny principle which all operations are denied unless explicitly permitted by a rule requiring authenticated user identity and role verification. Anonymous writes to any community data collection must be blocked entirely.

Beyond rule configuration, the more robust architectural mitigation is to eliminate direct client-to-Firebase writes entirely. Community feedback submissions should flow through PHOENIX's backend API, which validates, sanitises, and rate-limits each submission before writing to Firebase. This server-mediated approach means that a Firebase security rule misconfiguration cannot be exploited by an external attacker because no external path for direct Firebase writes exists. Regular automated Firebase security rule audits should be scheduled to catch

configuration drift, as manual rule management in complex systems inevitably introduces errors over time.

Section 3 — AI Model and Correlation Engine Mitigations

The AI Model Processing component and the Correlation Engine carry the highest concentration of Critical-rated threats in the entire PHOENIX architecture. The risk identification rates ST-09 (adversarial model evasion) and ST-12 (model retraining poisoning) as Critical with High likelihood which meaning these are not theoretical edge cases but realistic, near-term risks that require genuine controls before the system goes live. The specific characteristic of threats at this layer that makes them particularly dangerous is identified clearly in the risk document: they produce a system that appears to be functioning normally while systematically failing its core mission. The AI model generates outputs, the Correlation Engine produces risk scores, the DMT review queue receives escalations, but all of these outputs are wrong because the model's reasoning has been corrupted without triggering any operational alarm.

Mitigation M-07 — Input Sanitisation and Pre-Inference Anomaly Screening

Threats addressed: ST-09 (Tampering, Critical), ST-18 (Information Disclosure, High)

Vulnerability addressed: V13 — AI models can be fooled by carefully crafted content

Control type: Preventive / Detective

Component: AI Model Processing — Scam Detection / Threat Classification

The risk identification describes ST-09 as one of the most realistic high-likelihood threats in the system: an attacker does not need access to PHOENIX as they simply send varied inputs and observe how the model responds, mapping its decision boundaries through patient systematic probing. Vulnerability V13 captures this correctly as it’s not a flaw in the implementation but a fundamental characteristic of trained classifiers that can only detect what they have learned to detect. The mitigation applies a second, independent screening layer before content reaches the main classification model: a separately trained anomaly detector that evaluates the statistical properties of incoming content rather than matching it against known scam patterns.

Because this anomaly detector does not share the main model's decision boundaries, adversarial content engineered to evade the main classifier does not automatically evade the anomaly screen. Additionally, the main model's outputs should include output confidence thresholding and any classification below a defined confidence level is routed to enhanced review rather than automatically dismissed as low risk. This directly counters the confidence score manipulation attack: an attacker who crafts content to produce a high-confidence benign classification cannot simultaneously keep the confidence score below the threshold, creating two independent barriers that must both be bypassed for adversarial content to pass through undetected.

Mitigation M-08 — Internal Timestamping Layer for Correlation Engine Independence

Threats addressed: ST-11 (Tampering, Critical)

Vulnerability addressed: V2 — No detection of unusual patterns in incoming data

Control type: Preventive

Component: Correlation Engine — Cross-refer Scams & Disasters / Risk Scoring

ST-11 is rated Critical because it targets the feature that makes PHOENIX fundamentally different from conventional threat intelligence platforms as its event-correlation capability. If the Correlation Engine's temporal cross-referencing can be disrupted by manipulated timestamps, genuine disaster-correlated threats are scored as routine and never escalated to DMT review, and

community alerts are silently suppressed. The mitigation removes the attacker's ability to influence the Correlation Engine's temporal reference entirely.

PHOENIX's ingestion layer should record an independent internal ingestion timestamp for every data record at the moment it enters the system before any external timestamp value in the record is used or trusted. When the Correlation Engine evaluates whether a scam report is temporally correlated with an active disaster, it uses this internal ingestion timestamp as its primary reference, treating the source-provided timestamp as informational metadata only. An attacker who manipulates timestamps in the source data cannot affect the Correlation Engine's event-window calculation because the temporal reference it uses is generated at a point in the pipeline that is not accessible to an external attacker.

Mitigation M-09 — Retraining Data Quality Gate and Randomised Retraining Schedule

Threats addressed: ST-12 (Tampering, Critical)

Vulnerability addressed: V21 — Quality filter on feedback is not foolproof

Control type: Preventive / Detective

Component: Model Retraining — Feedback Collection Loop

ST-12 is rated Critical with High likelihood as the risk identification notes that coordinated adversarial feedback submissions require no technical sophistication beyond organisation and persistence, making this one of the most accessible attack vectors in the PHOENIX threat landscape. The feedback timing attack specifically exploits the predictability of the retraining schedule to concentrate poisoned feedback immediately before a retraining run. Three complementary mitigations address this. First, a data quality gate applies statistical analysis to all feedback received before each retraining cycle, comparing the incoming label distribution against the historical baseline. A sudden spike in false positive classifications or a shift in label distribution toward any specific threat category triggers a quarantine flag and human review before the data enters training.

Second, the retraining schedule should be randomised within a defined window rather than fixed on a predictable cadence. An attacker who cannot predict when the next retraining cycle will occur cannot time their poisoning campaign effectively. Third, every retrained model version must be evaluated against a curated holdout test set of confirmed disaster-context scam examples before deployment. If the retrained model's accuracy degrades below a defined threshold relative to the previous version, deployment is blocked and the retraining data is audited for contamination. These three controls together directly address vulnerability V21 which the current quality filter that the risk identification identifies as insufficient is strengthened into a multi-stage quality assurance pipeline.

Mitigation M-10 — Model Version Control with Mandatory Rollback Capability

Threats addressed: ST-09 (Tampering, Critical), ST-12 (Tampering, Critical)

Vulnerability addressed: V13 — AI models can be fooled by carefully crafted content

Control type: Corrective

Component: AI Model Processing / Model Retraining

Regardless of the preventive controls applied to the retraining pipeline, the possibility that a degraded model version reaches deployment must be planned for. Every trained model version must be stored in a version-controlled repository with full metadata about its training dataset, evaluation metrics, and the identity of the administrator who approved deployment. This

versioning enables rollback to the previous validated version within a defined Recovery Time Objective if the current version is found to be performing below acceptable accuracy thresholds by restoring Phoenix's detection capability without requiring a full retraining cycle from scratch.

Rollback authorisation must require explicit approval from a system administrator with appropriate permissions, and the action must be logged with full identity attribution. This prevents a malicious insider from rolling back to an older, less capable model version as an attack strategy. An automated canary evaluation should run the candidate model against a live sample of real-time traffic for a defined period before full deployment, providing a final detection opportunity for degraded performance before it affects the full production system and communities relying on Phoenix's alerts.

Section 4 — Authentication and Access Control Mitigations

The authentication boundary carries four Critical-rated threats according to the risk identification: DMT login spoofing (ST-03, rated High likelihood), privilege escalation via session management (ST-25), RBAC misconfiguration (ST-26), and Kafka broker privilege escalation (ST-27, addressed in Section 2). The risk identification makes a particularly important observation about the DMT login threat: DMT staff working during a disaster are significantly more vulnerable to phishing attacks than on a normal day which high pressure, time urgency, and context-appropriate messaging all reduce the scrutiny applied to suspicious communications. This elevated likelihood during disaster conditions, combined with the Critical impact of a compromised DMT account, makes this boundary the most consequential human-facing security priority in the system.

Mitigation M-11 — Multi-Factor Authentication for All DMT Accounts

Threats addressed: ST-03 (Spoofing, Critical), ST-25 (Elevation of Privilege, Critical)

Vulnerability addressed: V5 — DMT staff more vulnerable during disasters

Control type: Preventive

Component: DMT User Login

The risk identification rates ST-03 as Critical with High likelihood which the highest likelihood rating assigned to any spoofing threat in the system and vulnerability V5 specifically identifies that DMT staff are more vulnerable during disasters. MFA directly breaks the attack chain that the spear-phishing scenario exploits: even a perfectly crafted phishing page that successfully captures a valid username and password cannot complete authentication without the second factor that only the genuine analyst holds. All DMT accounts must require MFA with no exemptions for any role level. TOTP-based authenticator applications are preferred over SMS-based MFA, which is vulnerable to SIM-swapping attacks also catalogued in the STRIDE analysis.

Account lockout should activate after a defined number of failed authentication attempts with an immediate alert to the security operations team. Login anomaly detection should flag successful logins from unexpected geographic locations, unusual times, or unrecognised device fingerprints. The combination of MFA, lockout policy, and anomaly detection creates three independent checks: MFA prevents credential theft from being sufficient for access, lockout prevents brute-force attacks from succeeding through volume, and anomaly detection identifies compromised accounts even when MFA has been bypassed through a sophisticated real-time phishing attack.

Mitigation M-12 — Principle of Least Privilege and Scheduled RBAC Audits

Threats addressed: ST-25 (Elevation of Privilege, Critical), ST-26 (Elevation of Privilege, Critical)

Vulnerability addressed: V6 — Wrong permission settings could give too much access

Control type: Preventive / Detective

Component: Role-Based Access Control

Both ST-25 and ST-26 are rated Critical and share vulnerability V6 which the risk identification identifies wrong permission settings as a structural weakness that gives too much access. The principle of least privilege applied rigorously to every role definition is the foundational mitigation: each role grants only the permissions explicitly required for its defined function, with no inherited or accumulated permissions from previous role assignments. Role definitions should be maintained in a version-controlled permission matrix that documents the exact permissions for each role, the business justification for each permission, and the date of last review.

Permission elevation requests must go through a formal approval workflow requiring a second authorised administrator to approve any access increase. Server-side role enforcement where access decisions are made on the server based on the authenticated user's role record rather than any client-submitted claim — prevents client-side role manipulation. Automated RBAC configuration scanning should run on a scheduled basis and alert whenever any role assignment deviates from the defined permission matrix, catching the kind of configuration drift that the risk identification identifies as particularly common during routine system updates when misconfiguration is accidentally introduced.

Mitigation M-13 — Immutable Audit Logging for All DMT Review Decisions

Threats addressed: ST-13 (Repudiation, High), ST-25 (Elevation of Privilege, Critical)

Vulnerability addressed: V8 — Legitimate users can cause harm without triggering alerts; V10 — No permanent record of what happened to the data

Control type: Detective

Component: DMT Review — Critical Cases / Alert Approval Workflow

The risk identification identifies ST-13 as High risk with the vulnerability being that legitimate users can cause harm without triggering alerts. The insider alert suppression attack scenario is designed specifically to be invisible by a malicious reviewer classifies genuine escalations as false positives through the system's normal workflow, then claims insufficient evidence after the fact. The mitigation is not a technical access control but a comprehensive, tamper-evident audit trail that makes every decision traceable regardless of the role or seniority of the person who made it.

Every DMT review decision must be logged with the reviewer's authenticated identity, a precise timestamp, the complete content of the reviewed threat, the AI model's risk score and classification rationale, the correlated disaster event data at the time of review, and the reviewer's stated rationale for their decision. These logs must be stored in a write-protected append-only system that is architecturally separate from the PHOENIX operational environment that stored in a system where not even a system administrator can modify existing entries. Automated statistical monitoring over audit logs should flag anomalies such as a single reviewer dismissing an unusually high proportion of escalations during a specific disaster event,

providing the detective signal needed to identify insider suppression before it causes further harm.

Mitigation M-14 — Session Management Controls Against Hijacking and Fixation

Threats addressed: ST-25 (Elevation of Privilege, Critical)

Vulnerability addressed: V6 — Wrong permission settings could give too much access

Control type: Preventive

Component: DMT User Login / Web Dashboard

The privilege escalation via session management threat (ST-25) is rated Critical as the risk identification notes that session fixation and token manipulation are well-documented attacks that provide a realistic escalation path for anyone who has obtained a low-privilege account. Session tokens must be cryptographically random with sufficient entropy, transmitted exclusively over TLS-encrypted connections, regenerated after every authentication event to prevent fixation, and assigned short expiry times with mandatory re-authentication required for high-privilege operations such as alert approval and model configuration changes.

JWT tokens used in the DMT authentication flow must be validated server-side on every request as the server verifies the signature, expiry, and issued-at claims against the expected values before honouring any request, regardless of what the client presents. CSRF protection using synchronised token patterns ensures that authenticated DMT sessions cannot be hijacked through cross-site request forgery. Content Security Policy headers prevent malicious scripts from being injected into the dashboard interface through XSS to steal session cookies. Together, these controls close the session management attack surface identified in vulnerability V6 at both the token level and the browser-interaction level.

Section 5 — Alert System Mitigations

The alert system carries the highest concentration of immediately life-safety-critical threats in the PHOENIX architecture. The risk identification rates three alert system threats as Critical alert delivery API denial of service (ST-20, High likelihood), alert system spoofing (ST-04, Critical), and the implicit threat of content tampering in transit. ST-20 receives the most alarming combination of ratings: High likelihood and Critical impact. The risk identification states this directly: community members and emergency services not receiving critical safety warnings during the most dangerous period of a disaster event is the worst possible outcome for a system whose entire purpose is to deliver those warnings. The mitigations for this section must guarantee delivery integrity, content authenticity, and channel availability simultaneously.

Mitigation M-15 — Digital Signatures on All Outgoing Alerts

Threats addressed: ST-04 (Spoofing, Critical), alert content tampering in transit

Vulnerability addressed: V18 — Phoenix cannot control alerts after they leave the system

Control type: Preventive

Component: Alert System — Send Secure Alert / API Dispatch

The risk identification identifies vulnerability V18 directly once alerts leave PHOENIX, the system cannot control what happens to them in transit or at the recipient end. Digital signatures address this loss of control by binding PHOENIX's identity to the alert content cryptographically. Every alert dispatched must be signed using a private key held exclusively within PHOENIX's secure key store. The corresponding public key is distributed to all authorised recipients like emergency services agencies, community alert platforms,

VicEmergency integration by enabling them to independently verify both the origin and integrity of every alert they receive.

An alert that does not carry a valid PHOENIX signature is rejected by any recipient performing verification. An alert whose content has been modified in transit will fail signature verification because the modified content no longer matches the hash that the signature was computed over. This simultaneously addresses ST-04 spoofing which an attacker who steals alert dispatch credentials can send messages through the channel but cannot sign them with PHOENIX's private key and content tampering, where a state-sponsored attacker with the ability to intercept encrypted communications modifies alert content before delivery. The private key must be stored in a hardware security module or equivalent, rotated on a defined schedule, and its usage logged on every signing operation.

Mitigation M-16 — Secrets Management for Alert API Credentials

Threats addressed: ST-04 (Spoofing, Critical)

Vulnerability addressed: V18 — Phoenix cannot control alerts after they leave the system

Control type: Preventive

Component: Alert System — Authentication of Medium / Third-Party API Credentials

The alert spoofing scenario exploits stolen API credentials which obtained through phishing, code repository exposure, or supply chain compromise. The fundamental mitigation is the elimination of any context where alert dispatch credentials can be stolen. API keys, OAuth tokens, and other alert channel credentials must be stored exclusively in a dedicated secrets management vault, never hardcoded in application code, configuration files, or version control repositories. All development team members should understand and follow this policy, as the most common real-world credential exposure is accidental commitment to a public repository during development.

Access to secrets should be granted to application processes through short-lived dynamic credentials generated at runtime that automatically expire after a defined period, so that a stolen credential has a narrow window of validity even if the theft is not immediately detected. All credential usage should be logged with timestamps and source identifiers. Anomaly detection on alert dispatch patterns by flagging any request originating from an unexpected source IP, occurring at an unusual time, or deviating from normal alert volume and frequency which provides the detective layer that identifies credential misuse after it has begun.

Mitigation M-17 — DDoS Protection and Redundant Delivery Channels

Threats addressed: ST-20 (Denial of Service, Critical — High likelihood)

Vulnerability addressed: V3 — Single point of failure on external API connections

Control type: Preventive / Corrective

Component: Alert System — API Endpoints / Alert Delivery Infrastructure

ST-20 receives the most urgent combination of ratings in the entire risk identification as Critical impact and High likelihood and vulnerability V3 identifies a single point of failure on external API connections as the structural weakness that makes the attack possible. The primary mitigation is a cloud-based DDoS protection layer that absorbs attack traffic before it reaches the PHOENIX alert delivery infrastructure. Separate rate limit buckets must be configured for alert dispatch traffic specifically, ensuring that a DDoS against the general PHOENIX API cannot consume the rate limit capacity reserved for community alert delivery.

Architectural redundancy is the second layer: PHOENIX must deliver alerts through multiple independent channels simultaneously as SMS gateway, push notifications via Firebase, email, and VicEmergency integration. An attacker who successfully disrupts one channel does not suppress all alerts because the same alert is being dispatched in parallel through independent paths with independent infrastructure dependencies. The DMT dashboard must include a real-time delivery monitoring view showing the status of each dispatched alert across each channel by ensuring that a delivery failure is immediately visible to operators rather than silently occurring while the dashboard appears normal. This directly addresses the scenario identified in the attack documents where the DDoS causes silent failure invisible to the DMT.

Mitigation M-18 — Immutable Alert Delivery Audit Log

Threats addressed: ST-14 (Repudiation, High)

Vulnerability addressed: V10 — No permanent record of what happened to the data

Control type: Detective

Component: Alert System — Log the Alert / Retry on Failure

Vulnerability V10, the absence of a permanent record of what happened to data affects both the alert dispatch log (ST-14) and the database access log (ST-15). For the alert system specifically, the repudiation risk is that without an immutable delivery log there is no way to verify after a disaster whether a critical warning was actually sent, whether it reached its intended recipients, and whether its content was intact at the point of dispatch. Every alert must be recorded in an append-only audit log capturing the complete alert content, a cryptographic hash of the content, the dispatch timestamp, delivery channels used, confirmation status per channel, and any retry attempts.

This log must be stored architecturally separately from the PHOENIX operational database in a write-protected system where even a system administrator cannot modify existing entries. In the event of a DDoS attack or delivery failure, the audit log provides the documentation needed to demonstrate that PHOENIX dispatched the alert and that the failure occurred in the external delivery infrastructure rather than within the system. This accountability record is critical for maintaining public and government confidence in PHOENIX as a reliable emergency management tool after any incident.

Section 6 — Database and Storage Mitigations

The Scam DB and Cyber Threat DB are identified in the risk identification as the most targeted components in the entire PHOENIX architecture, appearing in five separate threat rows. Three of those threats are rated Critical as database tampering via SQL injection (ST-10), personal data disclosure (ST-17), and ransomware encryption (ST-24). The shared vulnerability across the tampering and disclosure threats is V9 which malicious code could reach the database layer by reflecting that the primary attack path for both is through insufficient input validation on the database interface. The ransomware threat shares vulnerability V11 as backups could be wiped out along with primary data which is addressed through a distinct architectural mitigation.

Mitigation M-19 — Parameterised Queries and Least-Privilege Database Access Controls

Threats addressed: ST-10 (Tampering, Critical), ST-17 (Information Disclosure, Critical)

Vulnerability addressed: V9 — Malicious code could reach the database layer

Control type: Preventive

Component: Scam DB / Cyber Threat DB — Database Access Layer

Vulnerability V9 is the single most consequential database vulnerability in the system because it enables both the highest-priority tampering threat and the most severe privacy risk simultaneously. Parameterised queries also called prepared statements are the definitive mitigation for SQL injection: by separating the query structure from the data values at the database driver level, they make it structurally impossible to inject SQL commands through data inputs regardless of what the input contains. All database interactions in PHOENIX must use parameterised queries exclusively, with no dynamic SQL construction that concatenates user-supplied values into query strings.

Database access must be restricted through role-based controls at the database level independently of application-level controls. The database accounts used by different PHOENIX services should have only the permissions they need: the AI model's read account has no write permissions; the data ingestion pipeline's write account has no delete permissions; delete operations require a separate administrative account whose every invocation generates an immediate security alert. Field-level encryption for sensitive personal data like names, addresses, phone numbers, health information belonging to disaster victims which ensures that even a successful database breach does not expose raw personal information, directly addressing the Critical-rated information disclosure risk ST-17.

Mitigation M-20 — Encrypted Offsite Backups with Tested Recovery Procedures

Threats addressed: ST-24 (Denial of Service — Ransomware, Critical)

Vulnerability addressed: V11 — Backups could be wiped out along with primary data

Control type: Corrective

Component: Scam DB / Cyber Threat DB

The risk identification rates ST-24 as Critical and notes explicitly that vulnerability V11which backups being wiped out alongside primary data is what makes ransomware catastrophic rather than merely disruptive. The attack scenario document identifies that the ransomware is timed to detonate 24 to 48 hours before peak disaster conditions, when the pressure to restore service is at its maximum and the organisation's negotiating position is its weakest. The mitigation must eliminate the conditions that make ransom payment the path of least resistance.

Encrypted offsite backups stored in a network segment completely isolated from the PHOENIX operational environment are the primary control. The backup infrastructure must not be accessible from the operational environment where ransomware that encrypts the primary databases must have no path to the backup store. Backups should be taken on a defined schedule with retention calibrated to ensure that a multi-day ransomware campaign cannot destroy all valid recovery points. Critically, recoverability must be tested through scheduled restore exercises rather than assumed: a backup that has never been successfully restored to a working system is not a backup but an untested assumption. Recovery procedures must specify a defined Recovery Time Objective, and drills must verify that this RTO is achievable under disaster-concurrent conditions.

Mitigation M-21 — Immutable Database Audit Logging for All Read, Write, and Delete Operations

Threats addressed: ST-15 (Repudiation, High), ST-10 (Tampering, Critical)

Vulnerability addressed: V10 — No permanent record of what happened to the data

Control type: Detective

Component: Scam DB / Cyber Threat DB — Audit Trail

Vulnerability V10, no permanent record of what happened to data affects the database layer in a particularly consequential way: the silent database record deletion attack scenario is designed specifically to exploit the absence of audit logging. An attacker who deletes specific scam record categories and also deletes the access logs that would document the deletion leaves no traceable evidence of the attack. The immutable audit log requirement closes this gap: every read, write, and delete operation on both databases must be recorded in a write-protected, append-only log store that is architecturally separate from the databases it records.

The log must capture the authenticated user identity, timestamp, affected table and record identifiers, and for any write or delete operation the before and after state of the modified record. Storage in a system where even a database administrator cannot modify existing entries ensures that compromising the database does not simultaneously destroy its audit trail. Automated monitoring should run statistical analysis over the audit logs, flagging any pattern of targeted deletions affecting specific threat categories, any bulk deletions, or any database access from service accounts at unusual times. These anomaly alerts are the primary detective mechanism for identifying a silent deletion campaign before it causes sufficient model degradation to affect Phoenix's real-world detection performance.

Mitigation M-22 — Network Segmentation and Micro segmentation Between System Components

Threats addressed: ST-24 (Denial of Service — Ransomware, Critical), ST-10 (Tampering, Critical), ST-17 (Information Disclosure, Critical)

Vulnerability addressed: V9, V11 — Database vulnerability and backup exposure

Control type: Preventive

Component: Infrastructure — Network Architecture

A horizontal ransomware propagation attack which the risk identification identifies as the mechanism enabling V11 succeeds because the malware can move laterally from a compromised component to the backup storage over the same network. Network segmentation that places the PHOENIX operational environment, the database layer, and the backup storage in separate network segments with strict firewall rules between them removes this lateral movement path. A malware infection that begins in the stream processing layer cannot traverse a properly configured network boundary to reach the databases or backup store.

Micro segmentation goes further than traditional VLAN-based network segmentation by applying access control rules at the individual service level rather than the subnet level, so that even components within the same operational network segment can only communicate with the specific other components they need to interact with. For example, the AI model inference service can read from the Scam DB but cannot write to it and cannot communicate with the backup storage system at all. This principle of network-level least privilege complements the application-level access controls specified earlier and ensures that a compromise of one component does not automatically provide network access to every other component in the system.

Mitigation Mapping — Summary Table

The following table provides a consolidated reference of all twenty-two mitigations mapped in this document. Each row identifies the mitigation code, the STRIDE threats it addresses with their risk ratings from the CY005 Identify Risks analysis, the control type, the PHOENIX component it applies to, and how the control works.

#	Mitigation	STRIDE Threats + Risk	Control Type	Component	Brief Description
Section 1 — External Data Feed Mitigations (M-01 to M-04)					
M-01	**TLS 1.3 with Certificate Pinning**	ST-01 (Critical) ST-02 (Critical) ST-06 (Critical)	**Preventive**	External Disaster Feed / Scam Feed	All external feed connections use TLS 1.3 with certificate pinning, ensuring no man-in-the-middle interception or feed impersonation can succeed undetected.
M-02	**Cryptographic Hash Verification of Feed Data**	ST-06 (Critical) ST-07 (High)	**Preventive / Detective**	Data Validation Layer	Every incoming data packet carries an HMAC hash that PHOENIX verifies before admission — catching tampering that TLS alone cannot detect, such as source-level manipulation by a supply-chain attacker.
M-03	**Rate Limiting and Anomaly Detection on Feed Volumes**	ST-02 (Critical) ST-12 (Critical)	**Detective / Preventive**	Data Ingestion Layer	Baseline monitoring detects submission volume spikes; anomalous feeds enter a quarantine buffer and the AI model's weighting of that source is temporarily reduced until human review clears it.
M-04	**Redundant Feeds, Cached Fallback, and Circuit Breaker**	ST-22 (Critical) ST-23 (Medium)	**Preventive / Corrective**	Data Ingestion / Retry Mechanism	Multiple feed endpoints with automatic failover and a cached data fallback ensure PHOENIX continues operating during a DoS against external APIs; the circuit breaker prevents the retry loop from becoming a self-inflicted DoS.
Section 2 — Stream Processing and Pipeline Mitigations (M-05 to M-07)					
M-05	**Kafka Broker Authentication and Per-Topic ACLs**	ST-08 (Critical) ST-21 (Critical) ST-27 (Critical)	**Preventive**	Stream Processing — Kafka	Mutual TLS authentication and per-topic Access Control Lists restrict every service account to its minimum required permissions; all messages are signed by producer, and downstream consumers reject any unsigned or unexpectedly sourced message.
M-06	**Firebase Security Rules and Server-Mediated Writes**	ST-19 (High) ST-08 (Critical)	**Preventive**	Stream Processing — Firebase	Default-deny Firebase security rules and server-mediated write architecture ensure no external client can write directly to the community feedback database, eliminating the misconfiguration attack surface.
M-07	**Schema Validation at Pipeline Entry Points**	ST-07 (High) ST-08 (Critical)	**Preventive**	Data Validation / Stream Processing	Whitelist-based schema validation rejects any message that does not precisely match expected field types, value ranges, and structure; all rejections are logged with source and field details for anomaly detection.
Section 3 — AI Model and Correlation Engine Mitigations (M-08 to M-11)					
M-08	**Input Sanitisation and Pre-Inference Anomaly Screening**	ST-09 (Critical) ST-18 (High)	**Preventive / Detective**	AI Model Processing	A second, independently trained anomaly detector screens content before the main classifier; output confidence thresholding routes low-confidence classifications to enhanced review rather than automatic low-risk dismissal.
M-09	**Internal Timestamping for Correlation Engine Independence**	ST-11 (Critical)	**Preventive**	Correlation Engine	PHOENIX records an independent internal ingestion timestamp at the moment data enters the system; the Correlation Engine uses this internal timestamp rather than the source-provided value, eliminating the timestamp injection attack vector.
M-10	**Retraining Data Quality Gate and Randomised Schedule**	ST-12 (Critical)	**Preventive / Detective**	Model Retraining Pipeline	Statistical analysis of pre-retraining feedback detects label distribution anomalies; deployment is blocked if the retrained model degrades below accuracy thresholds on a holdout test set; randomised retraining schedule prevents timing attacks.
M-11	**Model Version Control with Rollback Capability**	ST-09 (Critical) ST-12 (Critical)	**Corrective**	AI Model / Model Retraining	Every model version is stored with full training metadata; rollback to the previous validated version is available within a defined RTO if the current model is found degraded; canary evaluation runs before full deployment.

Section 4 — Authentication and Access Control Mitigations (M-12 to M-15)					
M-12	**Multi-Factor Authentication for All DMT Accounts**	ST-03 (Critical) ST-25 (Critical)	**Preventive**	DMT User Login	MFA using TOTP-based authenticator applications breaks the credential theft attack chain; account lockout and login anomaly detection provide additional layers against brute-force and post-MFA compromise.
M-13	**Principle of Least Privilege and Scheduled RBAC Audits**	ST-25 (Critical) ST-26 (Critical)	**Preventive / Detective**	Role-Based Access Control	Version-controlled permission matrix enforces minimum permissions per role; automated RBAC configuration scanning alerts on any deviation; permission elevation requires formal two-administrator approval.
M-14	**Immutable Audit Logging for DMT Review Decisions**	ST-13 (High) ST-25 (Critical)	**Detective**	DMT Review — Alert Approval	Every review decision is logged with reviewer identity, timestamp, threat content, risk score, and stated rationale in a write-protected append-only store; statistical monitoring flags anomalous dismissal patterns.
M-15	**Session Management Controls Against Hijacking and Fixation**	ST-25 (Critical)	**Preventive**	DMT User Login / Web Dashboard	Cryptographically random tokens with short expiry, mandatory regeneration on login, CSRF synchronised token patterns, and Content Security Policy headers close all documented session attack vectors in the STRIDE analysis.
Section 5 — Alert System Mitigations (M-16 to M-19)					
M-16	**Digital Signatures on All Outgoing Alerts**	ST-04 (Critical) Alert content tampering	**Preventive**	Alert System — API Dispatch	Every dispatched alert is signed with PHOENIX's private key; recipients verify the signature independently — an alert whose content was modified in transit or forged by a credential thief fails verification and is rejected.
M-17	**Secrets Management for Alert API Credentials**	ST-04 (Critical)	**Preventive**	Alert System — API Credentials	Alert dispatch credentials are stored exclusively in a secrets vault with dynamic short-lived tokens generated at runtime; usage is logged and anomaly detection flags any dispatch from unexpected sources or times.
M-18	**DDoS Protection and Redundant Alert Delivery Channels**	ST-20 (Critical — High likelihood)	**Preventive / Corrective**	Alert System — Delivery Infrastructure	Cloud DDoS mitigation with separate rate limit buckets for alert dispatch; simultaneous delivery through SMS, push, email, and VicEmergency means a single channel suppression does not block all alerts.
M-19	**Immutable Alert Delivery Audit Log**	ST-14 (High)	**Detective**	Alert System — Audit Log	Every dispatched alert is recorded in an append-only log with content hash, channel status, and delivery confirmation; stored separately from the operational database so a system compromise cannot destroy the delivery record.
Section 6 — Database and Storage Mitigations (M-20 to M-22b)					
M-20	**Parameterised Queries and Least-Privilege Database Access**	ST-10 (Critical) ST-17 (Critical)	**Preventive**	Scam DB / Cyber Threat DB	Parameterised queries eliminate SQL injection structurally; per-service database accounts enforce least privilege; field-level encryption protects personal data of disaster victims even against a successful breach.
M-21	**Encrypted Offsite Backups with Tested Recovery Procedures**	ST-24 (Critical)	**Corrective**	Scam DB / Cyber Threat DB	Network-isolated encrypted backups prevent ransomware lateral propagation to backup storage; scheduled restore exercises verify that the defined RTO is achievable under disaster-concurrent conditions.
M-22	**Immutable Database Audit Logging**	ST-15 (High) ST-10 (Critical)	**Detective**	Scam DB / Cyber Threat DB — Audit	Every database read, write, and delete is recorded in a write-protected append-only log with before/after state; automated statistical monitoring detects targeted deletion patterns before model degradation becomes apparent.
M-22b	**Network Segmentation and Micro segmentation**	ST-24 (Critical) ST-10 (Critical) ST-17 (Critical)	**Preventive**	Infrastructure — Network Architecture	Separate network segments for operational, database, and backup layers prevent ransomware lateral movement; micro segmentation restricts each service to only the components it must communicate with.